

Jerry CMS 线上后台 · 管理员登录配置指南

适用站点: <https://callmiruko.cc> | 管理员邮箱: 仅你本人掌握, 保存在服务端环境变量中, 页面与代码库均不展示 | 预计耗时 15-25 分钟

先说现状 (代码已全部完成并上线):

- ① 线上后台 `/admin/` 已加上登录门, 任何人打开都必须先过邮箱验证码, 后台内容完全遮蔽;
 - ② 安全测试已通过: 非管理员邮箱发码直接 **403 拒绝**、不带登录凭证调用写接口 **401 拒绝**、伪造凭证 **401 拒绝**;
 - ③ 但排查发现你原来的 **Supabase 项目已经失效** (域名在全球 DNS 都查不到, 疑似免费项目长期闲置被回收), 所以登录邮件暂时发不出来;
 - ④ 线上保存功能还缺一个 **GitHub Token**。
- 按下面 7 步配完即可在任何电脑/手机上登录网站后台直接发文、改设置。

原理: 为什么黑客进不来

- **唯一管理员**: 管理员邮箱白名单保存在服务端环境变量里 (前端页面和公开代码库都看不到它), 其他邮箱在“发验证码”第一步就被拒绝, 根本收不到码、建不了会话。
- **验证码**: 6 位数字, 10 分钟过期、5 次输错作废、60 秒只能发一次。
- **每次操作都验票**: 后台每次保存都带登录票据, 服务器实时向 Supabase 验票并核对邮箱, 票据伪造/过期一律拒绝。
- **密钥永不进前端**: GitHub Token、Supabase 密钥只存在 Vercel 环境变量里, 浏览器里看不到。
- **保存即发布**: 线上每次保存都通过 GitHub API 提交回仓库, Vercel 自动重新部署, 约 1-2 分钟生效。

第一步: 重建 Supabase 项目 (约 5 分钟)

- 1 打开 <https://supabase.com> 登录 (国内网络打不开就挂梯子, 只在配置时需要, 以后用不到)。
- 2 点 **New project**: 名字随意 (如 `jerry-site`), 区域选 **Southeast Asia (Singapore)** (离中国最近), 设置并**牢记数据库密码**, 等项目初始化完成 (约 2 分钟)。
- 3 取两个值 (后面要用, 先复制到记事本):
 - 左下角齿轮 **Project Settings** → **Data API** (旧版叫 API): 复制 **Project URL**, 形如 `https://xxxxxxx.x.supabase.co` **公开值**
 - 同一页面 **API Keys** 区域: 复制 **publishable / anon key** (`sb_publishable_...` 开头) **公开值**
 - 再复制 **service_role / secret key** (`sb_secret_...` 开头, 点 Reveal 才显示) **机密值** 这个只能放进环境变量, 绝不发给别人、不贴前端。

注: 新版 Supabase 界面把密钥分成 publishable (公开) 和 secret (机密) 两类, 对应旧版的 anon 和 service_role。

第二步：创建验证码数据表（约 2 分钟）

1 左侧菜单 **SQL Editor** → **New query**。

2 打开你项目仓库里的 `api/schema.sql`，**整份复制**粘贴进去，点 **Run**。看到 Success 即可。

这份脚本除了建登录验证码表，还会把前台通行证（积分/打卡/评论）的表一起建好，可重复运行。

如果只想最小化配置，只跑脚本第 10-17 行的 `email_otp_codes` 建表语句也能登录后台，但建议整份跑。

第三步：关闭公开注册（约 1 分钟，重要）

1 **Authentication** → **Sign In / Providers**（或 **Authentication** → **Settings**）。

2 找到 **Allow new users to sign up**（允许新用户注册）开关，**关掉**。

3 Email 登录保持开启即可。

这样全世界只有白名单邮箱能建立会话——管理员登录走的是服务端接口，不受这个开关影响。

第四步：创建 GitHub Token（约 3 分钟）

1 打开 <https://github.com/settings/personal-access-tokens/new>（Fine-grained token，细粒度令牌）。

2 填写：

- **Token name**： `jerry-cms-online`
- **Expiration**：选 90 天会过期（到期重做一次即可）；嫌麻烦选自定义最长 1 年。
- **Repository access**：选 **Only select repositories** → 勾选 `jerry-site`。
- **Permissions** → **Repository permissions** → **Contents**：改成 **Read and write**（读写），其他权限一律不动。

3 点 Generate token，复制 `github_pat_...` 开头的字符串 **机密值**，它只显示一次。

第五步：在 Vercel 配置环境变量（约 5 分钟）

打开 <https://vercel.com> → 你的 **jerry-site** 项目 → **Settings** → **Environment Variables**。

把里面旧的 `SUPABASE_URL`、`SUPABASE_SERVICE_ROLE_KEY`（旧项目已失效）编辑更新；没有的就 New Add。逐条添加如下：

变量名 (Key)	填什么 (Value)	环境
<code>SUPABASE_URL</code>	新项目的 Project URL, <code>https://xxxx.supabase.co</code>	Production
<code>SUPABASE_SERVICE_ROLE_KEY</code> 机密	新的 <code>sb_secret_...</code> 密钥	Production
<code>GITHUB_TOKEN</code> 机密	刚生成的 <code>github_pat_...</code>	Production
<code>RESEND_API_KEY</code> 可能已有	Resend 后台 API Keys 页面的 <code>re_...</code> ；旧值若还在就不用动	Production
<code>ADMIN_EMAIL</code> 必填	你的管理员 Gmail 地址（即你用来登录后台的邮箱）；以后要加多个管理员用英文逗号分隔。 不要填错，否则收不到登录码	Production

Resend 注意：免费版自带的发件邮箱 `onboarding@resend.dev` **只能发给你 Resend 账号注册时用的那个邮箱**。所以请确认你的 Resend 账号就是用**你的管理员 Gmail**（即填进 `ADMIN_EMAIL` 的那个）注册的；若不是，去 Resend 用该邮箱注册一个账号并替换 `RESEND_API_KEY`。

第六步：重新部署（约 1 分钟）

- 1 Vercel 顶部 **Deployments** 标签 → 找到最上面一条部署 → 右侧 ... → **Redeploy**（环境变量改完必须重新部署才生效）。
- 2 等约 1-2 分钟状态变 Ready。

第七步：把两个公开值发给我（约 1 分钟）

新 Supabase 项目的 **Project URL** 和 **sb_publishable_公开密钥**（这两个本来就是设计为公开的，贴给我无安全风险）发给我，我会替换前台 3 处引用（首页、博客页、后台登录页）并发布——这样前台的通行证登录/积分系统也会一起恢复。

当然你也可以自己改：仓库里搜索旧值 `yvtvhanawoaepwfsgqqnzs` 和 `sb_publishable_EfxYndz6...`，全部替换成新值。

验证成功

打开 <https://callmiruko.cc/admin/index.html> → 手动输入你的管理员邮箱 → 点“发送验证码” → Gmail 收到 6 位码 → 输入后进入后台 → 右下角出现“● 线上编辑模式”浮条即成功。登录页不会显示任何邮箱地址，陌生人无法得知管理员是谁。

在任何电脑、手机浏览器登录都一样可用；登录状态会记住，过期后重新收一次码即可。

线上后台能做什么 / 不能做什么

功能	线上后台	说明
写文章 / 改文章 / 删除 / 草稿	✅ 支持	保存即提交仓库并自动部署
说说、友链、项目、相册、评论管理	✅ 支持	同上
页面布局、外观、桌宠动作包设置	✅ 支持	同上
站点设置 (昵称/背景/社交/音乐等)	✅ 支持	密钥类字段 (AI Key、图床 Token) 线上不可改, 由环境变量/本地管理
上传图片 (≤4MB)	✅ 支持	Serverless 请求体上限 4MB
大文件 (zip/exe/视频)、网站演示包上传	❌ 仅本地	体积超限且线上无法解压; 在本地编辑器操作, 发布后线上可见
Notion 同步、图床探针、一键发布按钮	❌ 仅本地	线上保存即自动发布, 无需这些按钮 (会显示友好提示)

故障排查

现象	处理
点发送验证码提示"登录服务尚未配置完成"	三个变量 (SUPABASE_URL / SERVICE_ROLE_KEY / RESEND_API_KEY) 没配齐或没 Redeploy
提示 fetch failed / 发信失败	SUPABASE_URL 复制错 (常见多了斜杠/空格), 或 service_role key 拿成了 publishable key
收不到邮件	查 Gmail 垃圾邮件; 确认 Resend 注册邮箱 = 你填的 ADMIN_EMAIL; 60 秒内重复发送会被冷却拦截
登录后保存报 GITHUB_TOKEN 错误	Token 没配、过期, 或忘了给 jerry-site 仓库 Contents 读写权限
保存后线上没变化	等 1-2 分钟 Vercel 部署完成; 去 Deployments 看最新一条是否 Ready
提示登录过期	重新收一次验证码登录即可

安全加固清单（做完即满分）

- ☒ 后台登录门 + 邮箱白名单（已上线）
- ☒ 写接口服务端强制鉴权（已上线）
- ☐ 关闭 Supabase 公开注册（第三步）
- ☐ GitHub Token 只授权单仓库 Contents 权限（第四步）
- ☐ GitHub → Settings → Emails → 勾选 **Keep my email addresses private**（隐藏提交记录里的真实邮箱；此后新提交已自动使用 noreply 隐私邮箱）
- ☐ 吊销之前在聊天里发过的旧 Notion Token（Notion → Settings → Integrations）
- ☐ 清理 Vercel 里旧的 `NOTION_TOKEN`、`NOTION_DATABASE_ID` 环境变量
- ☐ 机密值（sb_secret、github_pat、re_ 开头）只进 Vercel 环境变量，绝不贴进任何网页/聊天/仓库